
INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 — Information Security Governance

WEEK 3 ASSIGNMENT

Security Governance: Roles, Responsibilities and Real-World Application

Name: Abigail Ugoeze Silas

Student ID: C11/26/CGRCE/17260

GRC Engineering Programme — Cohort 11

Module 3: Roles and Responsibilities in Security Governance

PART A — Cross-Functional Governance Responsibility Model

A1. Governance Roles and Responsibilities

For security governance to be effective, it requires clearly defined authority distributed across multiple organisational functions. Security cannot be the exclusive domain of IT.

The following framework establishes the decision authority, accountability, consultation responsibilities, reporting obligations, and inter-functional relationships for each governance stakeholder in a large organisation.

1. Board of Directors / Board Audit and Risk Committee

Responsibility	Definition
Decision Authority	Approve enterprise cyber-risk appetite; ratify cybersecurity strategy; approve major security investments beyond executive authority thresholds
Accountability	Ultimate fiduciary accountability for material cyber-risk to shareholders and regulators; cannot delegate legal accountability
Consultation	Receives briefings from CISO, CRO, Legal; consults independent external advisers for assurance
Reporting Expectations	Receives a quarterly cyber-risk dashboard from the CISO; material incidents trigger ad hoc Board notification within 24–72 hours
Relationship to Other Stakeholders	Delegates operational execution to CEO; holds CEO accountable for security programme effectiveness; reviews CRO risk register

2. Chief Executive Officer (CEO)

Responsibility	Definition
Decision Authority	Approve cyber-risk acceptance above CRO threshold; authorise disclosure decisions on major incidents; champion security culture
Accountability	Accountable to the Board for the organisation's security posture; holds executive team accountable for compliance
Consultation	Consults CISO, CRO, Legal, and Finance before accepting major cyber-risk; consulted by CISO on incidents requiring Board notification
Reporting Expectations	Receives a monthly executive security summary; briefed immediately on incidents escalated to Board/Executive level
Relationship to Other Stakeholders	The bridge between Board risk appetite and operational delivery; appoints/removes CISO; resolves cross-functional conflicts between CISO, CRO, and business units

3. Chief Information Security Officer (CISO)

Responsibility	Definition
Decision Authority	Approve security policies, standards, and procedures; authorise security architecture decisions; direct incident response for High and Critical incidents; escalate to Board/Executive for Critical events
Accountability	Primary accountability for the security programme, control effectiveness, and incident governance; reports to CEO (and Board committee directly on material matters)
Consultation	Consulted by all functions on security-sensitive decisions; consults Legal on regulatory reporting obligations; consults Finance on budget impacts; consults HR on disciplinary matters
Reporting Expectations	Reports quarterly to the Board; monthly to the executive; maintains CISO incident log and risk register updates
Relationship to Other Stakeholders	Functional authority over IT Security, SOC, and GRC teams; collaborates with CRO on risk quantification; partners with Legal on regulatory breach notification; coordinates with HR on security awareness

4. Chief Risk Officer (CRO) / Enterprise Risk Function

Responsibility	Definition
Decision Authority	Approve enterprise cyber-risk acceptance within Board-approved risk appetite; maintain the enterprise risk register; challenge CISO risk assessments
Accountability	Accountable for maintaining an integrated view of cyber-risk alongside financial, operational, and strategic risk; ensures risk does not sit in silos
Consultation	Consulted by CISO on risk quantification; consults Finance on risk-cost modelling; provides input to Board risk reporting
Reporting Expectations	Reports to Board Audit and Risk Committee; maintains risk register updated at least quarterly with cyber-risk metrics from CISO
Relationship to Other Stakeholders	Acts as a check on CISO's operational focus; provides independent risk validation; coordinates with Legal on regulatory risk exposure

5. Legal / Privacy / Compliance

Responsibility	Definition
Decision Authority	Determine regulatory notification obligations and timelines; approve public communications on breaches; advise on third-party contract security requirements
Accountability	Accountable for regulatory compliance posture; manages regulatory breach notifications and legal exposure from security incidents
Consultation	Consulted by CISO on breach notification triggers; consulted by HR on disciplinary actions with legal implications; consulted by Finance on contractual penalties
Reporting Expectations	Reports regulatory exposure status to CISO and CRO; maintains a regulatory obligation tracker updated after each significant incident
Relationship to Other Stakeholders	Critical partner to CISO on incident response; provides legal privilege protection for certain investigation activities; advises Board on directors' liability

6. Finance

Responsibility	Definition
Decision Authority	Approve cybersecurity budget allocations; authorise emergency spend for incident response; approve cyber insurance arrangements
Accountability	Accountable for ensuring adequate security budget is provisioned and properly controlled; monitors financial impact of security incidents
Consultation	Consulted by CISO on budget adequacy; consulted by CRO on financial risk quantification; consulted by Legal on contractual penalties and insurance claims
Reporting Expectations	Receives monthly security spend report from CISO; reports security cost exposure in Board financial reporting
Relationship to Other Stakeholders	Provides financial approval and tracking for security programmes; works with CRO to quantify cyber-risk in financial terms

7. Human Resources

Responsibility	Definition
Decision Authority	Approve disciplinary actions for security policy violations; manage off-boarding processes to remove system access; own security awareness training delivery
Accountability	Accountable for managing personnel-related security risks (insider threats, access revocation, background screening); maintains confidentiality of HR-related security investigations
Consultation	Consulted by CISO on insider threat investigations; consulted by Legal on disciplinary actions with legal risk; consulted by IT on access revocation
Reporting Expectations	Reports security-related disciplinary actions to CISO and Legal on a case-by-case basis; reports security awareness training completion rates quarterly

Relationship to Other Stakeholders	Partners with CISO on security awareness; coordinates with IT for rapid access revocation; works with Legal on termination security controls
------------------------------------	--

8. Information Technology / Technology Operations

Responsibility	Definition
Decision Authority	Implement security controls at the technical level; approve changes within the change-control process; manage privileged access for system administration
Accountability	Accountable for implementing and operating security controls as directed by the CISO; owns change-management process integrity; responds to technical incidents
Consultation	Consulted by CISO on technical feasibility of security controls; consulted by DevOps and Cloud Operations on security architecture; consults Compliance on configuration standards
Reporting Expectations	Reports control implementation status, vulnerability metrics, and patch compliance to CISO monthly; escalates unresolved technical risks
Relationship to Other Stakeholders	Operational partner of the CISO; executes security decisions; coordinates with Finance on technology budget; receives access-revocation requests from HR

A2. RACI Matrix — Security Governance Activities

The matrix below assigns a single Accountable (A) role per activity and distinguishes Responsible (R), Consulted (C), and Informed (I) roles. Activities are drawn from the NDPC dataset findings and regulatory governance requirements.

Governance Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT
Security Strategy Approval	A	R	R	C	C	C	-	I
Enterprise Cyber-Risk Acceptance	A	R	C	R	C	C	-	I
Information Security Policy Approval	I	I	A	C	C	I	C	R
Major Incident Response Governance	I	C	A	C	R	C	C	R
Regulatory Breach Notification	I	C	R	C	A	C	-	C
Privileged Access Approval	I	-	A	I	C	I	C	R
Third-Party Cyber-Risk Acceptance	I	C	R	A	C	C	-	C
Security Awareness & Disciplinary Action	I	I	C	I	C	I	A	R
Cybersecurity Budget Prioritisation	I	C	R	C	I	A	I	C
Board Cyber-Risk Reporting	I	C	A	R	C	C	I	I
Cloud Security Posture Governance	I	I	A	C	C	C	-	R
Insider Threat Programme Oversight	I	C	A	C	C	I	R	C

Key: A = Accountable (single owner), R = Responsible (performs activity), C = Consulted (input required), I = Informed (notified). Gold cells indicate the Accountable role.

A3. Segregation of Duties and Conflict Resolution

Three significant conflicts of responsibility are identified below, each with its governance, fraud, compliance, or operational risk and a practical resolution control.

Conflict 1: CISO Owning Both Security Operations and Compliance Reporting

Element	Detail
Conflict	In cases where the CISO is both implementing security controls and reporting on their performance to the board and the regulators, there is independence deficiency, and the CISO may be motivated to provide favourable performance measurements to limit personal accountability.
Risk Type	Governance and Compliance Risk — regulatory assurance is undermined. Shareholders and regulators receive potentially biased reporting.
Practical Control	Set up a separate assurance function (internal audit or a dedicated GRC team) that will independently assess the effectiveness of the controls and issue its own security assurance report to the board. The GRC/Audit team should have a direct reporting channel to the Board Audit Committee, independent of the CISO.

Conflict 2: IT Operations Approving Its Own Changes (Change-Control Failure)

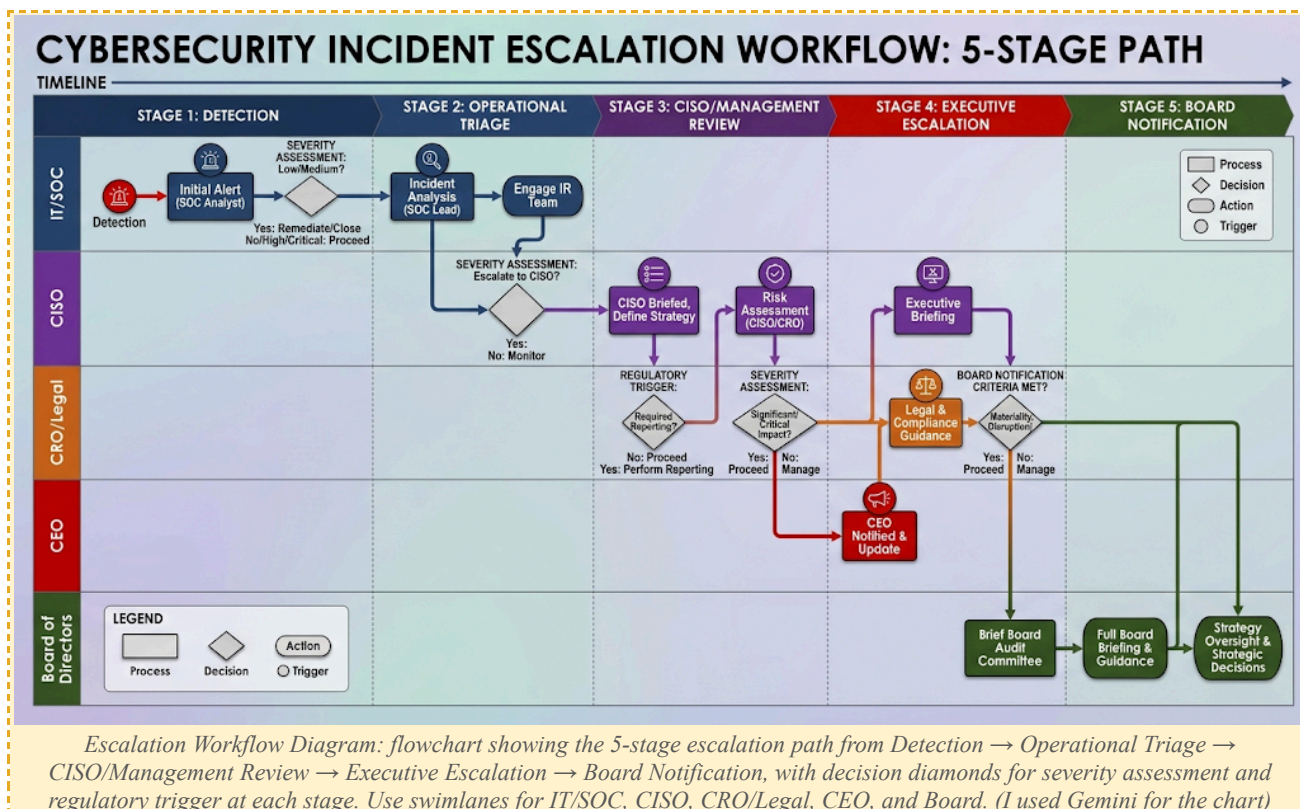
Element	Detail
Conflict	When IT personnel can both initiate and approve changes to production systems, there is a failure in the change control process. The NDPC data set shows 19 incidents of Misconfiguration due to change control failure.
Risk Type	Operational and Fraud Risk — unauthorised changes can introduce vulnerabilities or enable fraud; also creates compliance risk against ITIL and ISO 27001 change management requirements.
Practical Control	Enforce a mandatory four-eyes approval policy for all production changes: the initiator and an independent Change Advisory Board (CAB) member (who cannot be from the same team) must both approve. Changes to privileged accounts require an additional CISO or Security Manager sign-off.

Conflict 3: HR Managing Insider Threat Investigations Involving HR Data

Element	Detail
Conflict	HR holds employment data and simultaneously investigates policy violations. Where the subject of an investigation is in HR or the incident involves HR data (as seen in NDPC: Employment Data incidents in HR), HR cannot investigate itself without bias.
Risk Type	Compliance and Governance Risk — compromised investigations, potential legal exposure from unfair process, and data privacy risk if HR mismanages its own data incidents.
Practical Control	For any incident involving HR data or HR personnel, transfer of investigative leads to Legal (for privilege protection) and CISO (for technical forensic oversight), with HR recused from access to investigation details that concern its own staff. A documented escalation policy should define this trigger explicitly.

A4. Material Cyber-Risk Escalation Path

The escalation workflow below defines how a material cyber-risk moves from operational detection through management review to executive and board oversight. Trigger criteria, decision points, responsible roles, required evidence, timing, and final risk-acceptance authority are specified at each stage.



Stage 1 — Detection and Initial Triage (SOC / IT Security)

Parameter	Specification
Trigger	Security alert, user report, automated detection, or third-party notification of a potential security event
Responsible Role	SOC / IT Security Team (Operational escalation level)
Required Evidence	Incident ticket with: event timestamp, affected systems, initial indicators, preliminary severity assessment, containment actions taken
Decision Point	If Low/Medium severity with no regulatory exposure → resolve at the operational level. If High severity or regulatory exposure is suspected → escalate to Stage 2 within 2 hours.
Timing	a flowchart to initial classification: maximum 1 hour. Escalation triggers within 2 hours of classification.

Stage 2 — CISO / Department Head Review (CISO / Department Head level)

Parameter	Specification
Trigger	High severity classification, confirmed data exposure, regulatory trigger identified, or third-party involvement
Responsible Role	CISO (primary) and affected Department Head (accountable for business impact)
Required Evidence	Updated incident report with confirmed scope, affected data categories, regulatory exposure assessment, containment status, and preliminary cost estimate

Decision Point	If contained with no regulatory exposure → manage at CISO level with enhanced monitoring. Critical severity, confirmed data breach, or financial exposure material → escalate to Stage 3 within 4 hours.
Timing	CISO briefed within 2 hours of Stage 1 escalation. Stage 3 escalation decision within 4 hours of CISO engagement.

Stage 3 — Executive Escalation (Executive / CISO level)

Parameter	Specification
Trigger	Critical severity incident; confirmed breach of personal, financial, or regulated data; material third-party involvement; estimated cost impact exceeding USD 100,000
Responsible Role	CEO (decision authority); CRO (risk assessment); Legal (regulatory and legal exposure); Finance (financial impact)
Required Evidence	Executive incident brief: confirmed scope, affected individuals/records, regulatory notification obligations and deadlines, estimated financial exposure, reputational risk assessment, containment and recovery timeline
Decision Point	CEO accepts risk and activates crisis management protocol. If Board notification criteria met → escalate to Stage 4. Legal confirms regulatory notification obligation and initiates response.
Timing	CEO and Legal briefed within 4 hours of Stage 2 escalation. Regulatory notification clock starts from confirmed breach discovery.

Stage 4 — Board Notification (Board / Executive level)

Parameter	Specification
Trigger	Confirmed material cyber incident: confirmed data breach of >1,000 individuals; ransomware affecting critical systems; regulatory notification obligation activated; estimated financial impact >USD 500,000; public disclosure required
Responsible Role	CISO (brief author); CEO (presents to Board); Board Audit and Risk Committee Chair (convenes emergency meeting if required); CRO (risk sign-off); Legal (disclosure approval)
Required Evidence	Full Board incident report: executive summary, timeline, scope confirmation, regulatory obligations and deadlines, financial exposure, reputational impact, external legal advice, proposed public statement (if applicable), recovery plan with milestones
Decision Point	Board reviews and approves: risk acceptance decision, disclosure strategy, crisis communications, regulatory notifications, and any CEO authority extensions needed for emergency spend.
Timing	Board notified within 24 hours of Stage 3 escalation. Emergency Board session convened within 48 hours if required. Regulatory notifications per statutory deadlines (e.g., 72 hours under GDPR).
Risk-Acceptance Authority	Board of Directors / Board Audit and Risk Committee (final authority for material cyber-risk acceptance and residual risk sign-off).

A5. Cross-Functional Failure Scenario

Scenario: Delayed Third-Party Breach Notification Leading to Regulatory and Financial Consequences

NDPC's Finance department experiences a data breach through a compromised third-party payroll vendor. Personal and financial data of 4,500 employees and 2,200 corporate clients is exfiltrated. The following sequence illustrates how poor cross-functional coordination compounds the impact:

Stage	Poor Coordination Failure	Consequence
IT/SOC Detection	IT Security identifies unusual outbound traffic but classifies it as Medium severity due to incomplete visibility of data accessed. No immediate notification to CISO.	72-hour notification clock under data protection law is not started. The first-responder window is lost.
CISO ↔ Legal Gap	CISO assesses the breach technically but does not notify Legal for 36 hours, assuming it is 'not yet confirmed'. Legal is not consulted on regulatory notification triggers.	Regulatory breach notification is delayed past the 72-hour statutory deadline, creating direct regulatory liability.
Finance Exclusion	Finance is not informed of the breach for 5 days. Finance discovers the breach independently from vendor reports and initiates its own parallel response.	Duplicate efforts; Finance makes public statements to vendors without Board or Legal approval, creating additional legal exposure.
HR Inaction	HR is not notified despite employee personal data being exfiltrated. No employee communication is issued for 10 days.	Affected employees learn of the breach from the media. Employment tribunal risk escalates; reputational damage compounds.
Board Notification	CEO delays Board notification by 72 hours pending 'full investigation'. The board learns of regulatory non-compliance from a regulator inquiry rather than from management.	Loss of Board trust; personal liability risk for directors who were not notified; share price impact.

Five Recommendations for Improved Accountability and Collaboration

- Form a mandatory cross-functional Incident Response Governance Committee (IRGC) that meets within 4 hours of any High or Critical incident and includes CISO, Legal, Finance, HR, and Communications — with standing agenda and pre-agreed escalation authority.
- Document explicit notification trigger criteria in a Decision Matrix applicable by IT/SOC personnel without waiting for CISO confirmation — reducing risk of delayed notification clock activation.
- Implement a single source of truth (incident management platform) accessible by Legal, Finance, HR and CISO at the same time so that no team is working with different information or sending out independent communications.
- Mandatory governance control based on incident classification. All external communications related to a security incident (including vendor notifications and media statements) require Legal pre-approval.
- Conduct a post-incident cross-functional review (Hot Wash / After-Action Review) within 72 hours of the closure of all Critical incidents, with findings reported to the Board Audit Committee within 30 days — creating accountability for failures of coordination and continuous governance improvement.

PART B — The CISO, Board and Contemporary Governance

B1. Evolution of the CISO Role

The Chief Information Security Officer role has undergone a fundamental transformation over the last decade, shifting from a primarily technical function focused on perimeter defence to a strategic executive role with enterprise-wide governance authority and direct Board accountability. Understanding this evolution is essential to designing an effective security governance model.

In the early 2010s, the CISO role was largely operational: responsible for firewall management, vulnerability scanning, and IT security operations. The role typically sat within IT, reporting to the CIO, with limited visibility to executive leadership and almost no direct Board engagement. Security was viewed as a cost centre rather than a strategic function.

Between 2014 and 2018, a series of landmark breaches — including Target (2013), Anthem (2015), and Equifax (2017) — forced organisations to recognise that security failures produced enterprise-level consequences: regulatory fines, class-action litigation, executive terminations, and material share price impacts. Boards began demanding direct CISO accountability. This period saw CISOs gain seats on executive committees and begin presenting to Audit and Risk Committees directly.

From 2018 till date, regulatory developments including the EU General Data Protection Regulation (GDPR), the SEC's cybersecurity disclosure rules (2023), and the UK's NIS2 framework have formalised CISO governance obligations. The CISO is no longer only responsible for preventing incidents — they are now responsible for demonstrating that governance, controls, and risk acceptance are defensible to regulators, insurers, and shareholders.

B2. CISO Reporting Lines, Independence and Board Access

The CISO's reporting line significantly affects governance effectiveness. Three models are common in large organisations:

Reporting Model	Structure	Governance Effectiveness
CISO → CIO	Security sits within IT; CISO lacks independence from technology operational decisions	Low — security can be subordinated to IT delivery priorities; conflicts of interest with change management; Board access is indirect
CISO → CEO	Security is an enterprise function at executive level; CISO has direct executive authority	High — independence from IT operations; direct access to CEO and Board; security priorities are not subordinated to IT budget
CISO → CRO / CFO	Security is framed as a risk or financial function; CISO aligned with enterprise risk management	Medium-High — strong risk integration; Board access via CRO; may lack operational authority over IT

The governance literature strongly supports a direct CEO reporting line with an independent mandate to present to the Board Audit and Risk Committee at least quarterly (CISA, 2023; NCSC, 2022). Without this independence, CISOs may face structural pressures that compromise their ability to escalate material risks objectively.

B3. Regulatory Scrutiny, Executive Accountability and Digital Dependency

More regulation has significantly changed the role of CISOs. The new SEC's cybersecurity disclosure rules in 2023 require public companies to disclose material cybersecurity events within four business days and to have annual disclosure requirements regarding cybersecurity risk management and governance. Notably, these new regulations impose personal liability for CISOs in cases of making material misstatements about the controls.

Increased reliance on digital services in the business model of companies has increased the risks of security issues. Companies with cloud-first architectures, processing a lot of personal information, or providing real-time digital services face systemic risk when their controls do not work. As shown by the NDPC dataset, in 2025, Cloud Exposure becomes the category of incidents with the highest average cost. Thus, CISOs should govern in a technological environment that includes clouds, third parties, edge devices, and shadow IT—far more complex than an on-premises perimeter typical of the first CISO generation.

B4. Real-World Example — SolarWinds (2020–2021)

The SolarWinds supply chain attack is an excellent example of how CISO governance impacts the security of the organisation. The threat actor, Cozy Bear (APT29), introduced malicious code into software updates for SolarWinds Orion. As a result, around 18,000 organizations got compromised with the involvement of U.S. federal agencies.

In terms of governance, a few crucial flaws became obvious in this incident: SolarWinds had no controls in place to detect software build integrity issues related to the supply chain attacks; there was a deficiency in third party risk governance for most affected organizations; and CISO roles in many victim organizations were not empowered enough to introduce security requirements for the supply chain into the procurement process. Eventually, entities with CISO having executive power showed faster and better reactions in this case than others with siloed security within IT.

On the contrary, Lena Smart CISO at MongoDB is usually viewed as the positive example of CISO governance. In the course of MongoDB breach in October 2023, she managed to introduce rapid disclosure and transparent communication with customers, thus saving reputation. It became possible because of her executive power and mandate for crisis communication.

B5. Recommended CISO Governance Model for a Large Organisation

Based on current governance practice, regulatory requirements, and the evidence from the NDPC dataset, the following CISO governance model is recommended for a large, multi-departmental organisation:

Governance Element	Recommended Configuration	Justification
Reporting Line	CISO reports directly to CEO with mandatory, independent access to the Board Audit and Risk Committee	Ensures security is not subordinated to IT delivery priorities; enables direct Board engagement without intermediary filtering
Board Engagement	Quarterly CISO presentation to Board Audit and Risk Committee; ad hoc notification for Critical incidents within 24 hours	Meets regulatory expectations (SEC 2023, NIS2); enables Board to fulfil fiduciary duty on material cyber-risk
Independence Assurance	Separate Internal Audit or GRC function reviews and challenges CISO's control effectiveness reporting	Prevents conflicts of interest where CISO self-assesses their own programme
CISO Authority	CISO holds veto power over production changes involving security-sensitive systems; co-signs third-party vendor contracts above risk thresholds	Enables CISO to operationalise risk decisions, not only advise on them
Executive Integration	CISO is a member of the Executive Leadership Team and all major investment decision committees	Security considerations are built into strategic decisions, not retrofitted
Metrics and Accountability	CISO is accountable for a defined set of Board-level KPIs: SLA breach rate, unresolved Critical incidents, third-party risk coverage, and security awareness completion rates	Creates measurable accountability and enables performance-based governance

This model reflects the consensus of the CISA CISO Handbook (2023), the NCSC Board Toolkit (2022), and the practical requirements imposed by the SEC's cybersecurity disclosure rules. It positions the CISO as a strategic governance partner, not a technical service provider.

PART C — Major Security Breach Governance Case Study

C1. Incident Overview — Change Healthcare / UnitedHealth Group Ransomware Attack (February 2024)

In February 2024, Change Healthcare, which is a subsidiary of UnitedHealth Group (UHG) and the largest data processing clearinghouse in the US processing roughly 15 billion clinical transactions per year, was subject to a massive ransomware attack by the ALPHV/BlackCat threat actor group. The attack occurred on 21 February 2024 and resulted in the prolonged downtime of Change Healthcare's systems for several weeks, leading to interruptions to claims management, pharmacy operations, prior authorisations, and payments for hospitals, pharmacies, insurance providers, and clinicians across the United States.

The impact financially and operationally was profound. UnitedHealth Group calculated total losses of over USD 22 billion, with USD 3.3 billion worth of direct breach costs occurring in the first year. Roughly 190 million people were eventually found to have had their PHI exposed, making this the largest breach of healthcare information in the history of the United States. The investigation of the incident was started by the US Department of Health and Human Services (HHS), Senate Finance Committee, and House Energy and Commerce Committee. Andrew Witty, UHG's CEO, testified in front of Congress in May 2024.

C2. Pre-Incident Governance Arrangements

Based on the information available in the public domain, the following governance environment can be built:

- The company, Change Healthcare, was acquired by Optum (subsidiary of UnitedHealth Group providing health services) in October 2022 after several years of regulatory scrutiny. At the time of the breach, the implementation of the Change Healthcare's security governance into the UnitedHealth Group enterprise model had not been completed yet.
- UnitedHealth Group is a publicly traded company regulated by the obligation to provide any information on cybersecurity incidents to the SEC. Moreover, Change Healthcare, as a healthcare organization, should have adhered to the requirements of the HIPAA Security Rule including risk assessment, access control, and audit control.
- Testimonies before Congress and media reports (The New York Times, The Wall Street Journal, STAT News) revealed that the Change Healthcare's systems were based on legacy technologies and multi-factor authentication was not used at all remote access points during the incident.
- UnitedHealth Group has an appointed role of the Chief Information Security Officer (CISO); however, it is unknown from the public sources whether the CISO had jurisdiction over the legacy Change Healthcare environment after the acquisition.

C3. Governance Weaknesses and Failures

#	Governance Failure	Evidence / Basis
1	Absence of MFA on critical remote access infrastructure (Citrix portal)	Confirmed in Congressional testimony (CEO Andrew Witty, May 2024); attackers used compromised credentials without MFA challenge — a preventable control failure
2	Incomplete post-acquisition security integration and governance harmonisation	Change Healthcare systems remained on legacy infrastructure 16 months after acquisition; security governance standards were not uniformly applied to the acquired entity
3	Inadequate third-party and supply-chain risk governance across the healthcare sector	Change Healthcare processed claims for a significant proportion of US healthcare providers; no backup processing capacity or alternative routing existed — a single-point-of-failure governance failure
4	Delayed public disclosure and regulatory notification	Congressional scrutiny focused on the timeline between detection (21 February) and patient notification; HIPAA's 60-day individual notification requirement was strained by the breach's scale
5	Insufficient business continuity planning for enterprise-critical systems	Pharmacies and hospitals were unable to process claims for weeks; no effective continuity arrangement existed for a system processing billions of transactions — a governance failure in resilience planning
6	Ransom payment governance decision-making opacity	UHG reportedly paid a ransom of approximately USD 22 million; the governance process for that decision — who approved it, under what authority, with what Board oversight — has not been publicly disclosed, raising accountability concerns

C4. Roles of Board, Executive Leadership, CISO and Business Units

The UnitedHealth Group board had the ultimate governance responsibility in regard to the security of all the company subsidiaries, including Change Healthcare as a public company. It should be considered a Board-level issue in terms of security since the Board failed to assess material cyber risks and to mitigate them when integrating the subsidiary with the parent company's infrastructure.

It is the executives, in particular, the CEO and the executive accountable for the integration of Change Healthcare that must be held responsible for the inappropriate security integration timeline. Continuing to run the legacy infrastructure without establishing an appropriate cybersecurity policy and in particular MFA for almost one year and a half after the acquisition implies that the executives did not prioritize the security risk during the integration process.

There is some complexity in assessing the responsibility of the CISO function because there is little publicly available information about the scope of its authority over the legacy systems belonging to Change Healthcare. Nevertheless, a properly governed CISO function would: identify material legacy infrastructure and MFA-related risk in the course of the post-acquisition assessment; escalate it to executive management together with the plan for its mitigation; and maintain it as an open critical risk in the enterprise risk registry.

The Change Healthcare business unit responsible for the operation of the clearinghouse is accountable for the management and communication of the criticality of its systems to the company's cybersecurity governance program. Lack of business continuity planning reflects the deficiency of both business unit and enterprise cybersecurity governance.

C5. Regulatory, Legal, Financial and Reputational Consequences

- **Financial:** UHG estimated USD 22 billion+ in total costs over 2024; USD 3.3 billion in direct cybersecurity costs in the first year; significant business revenue loss from provider customers who switched clearinghouses.
- **Regulatory:** HHS investigated for potential HIPAA violations. The FTC examined antitrust implications of a single entity controlling such a large share of claims processing. Congressional hearings added significant political and regulatory pressure.
- **Legal:** Class-action lawsuits filed by healthcare providers and patients; provider organisations sought damages for revenue losses caused by the outage.
- **Reputational:** UHG's share price declined materially in the weeks following disclosure; the company faced sustained negative media coverage and Congressional testimony scrutiny.

C6. Governance Improvement Recommendations

- **MFA Mandatory Policy:** Enforce MFA as a non-negotiable baseline control on all remote access infrastructure across all entities, including recently acquired subsidiaries, with CISO sign-off required before any remote access system goes live.
- **Acquisition Security Integration SLA:** Implement a formal Post-Acquisition Security Integration Plan with Board-approved timelines and milestones. Any acquired entity must achieve enterprise security baseline compliance within 90 days of acquisition close.
- **Business Continuity for Critical Infrastructure:** Require enterprise-critical systems (processing >1 million transactions daily) to have documented, tested business continuity arrangements including alternative routing and failover capacity.
- **Third-Party Concentration Risk Governance:** Assess and disclose third-party concentration risk (where a single vendor's failure would cause industry-wide disruption) in the Board risk register with defined mitigation controls.
- **Transparent Incident Governance:** Define in advance the governance process and decision authority for ransom payment decisions, public disclosure, and regulatory notification, ensuring Board pre-approval of these frameworks rather than crisis-time improvisation.
- **Post-Acquisition CISO Authority:** Explicitly extend the enterprise CISO's mandate and authority to cover all subsidiary security environments, with a defined escalation path for legacy risks that cannot be remediated immediately.

Note: All the facts in this section are sourced from publicly available Congressional testimony, regulatory publications, and established news reporting.

PART D — NDPC Data Analysis and GRC Application

All calculations in this section are based on the 180-record NDPC Security Incidents Enhanced dataset (2024–2025). The full analysis workbook (GRC102_W3_Analysis_AbigailSilas.xlsx) contains supporting calculations, raw data, and charts. Original Incident_ID values are retained for traceability.

D1. Core Analysis

Total Incidents and Distribution by Incident Type

The NDPC dataset contains 180 simulated incidents spanning January 2024 to December 2025.

Incident Type	Count	% of Total	Notes
Malware	28	15.6%	Joint highest; persistent endpoint threat
Phishing	28	15.6%	Joint highest; primary credential harvesting vector
Data Leak	27	15.0%	Privacy and regulatory exposure dominant
Unauthorized Access	24	13.3%	IAM control failures (dormant accounts, excessive privileges)
Misconfiguration	19	10.6%	Change-control failures; growing cloud exposure in 2025
DDoS	19	10.6%	Network resilience gaps; capacity planning failures
Cloud Exposure	11	6.1%	Entirely 2025 — fastest-growing emerging category
Credential Theft	9	5.0%	Phishing-driven; MFA absence key enabler
Third-Party Breach	6	3.3%	Highest cost premium; supply-chain risk
Insider Threat	5	2.8%	Lowest count; highest average cost (\$138,506)
Lost Device	3	1.7%	Asset management gaps; growing in 2025
Policy Violation	1	0.6%	Emerging classification; cloud shadow IT

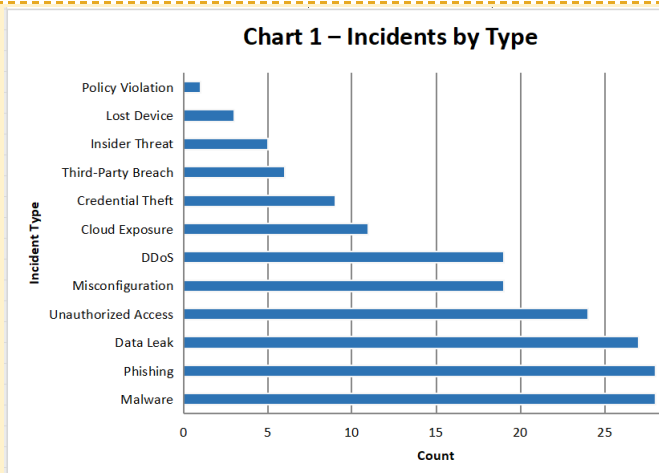


Chart 1 — Incidents by Type (Bar Chart from Analysis Workbook, Sheet: D1 – Core Analysis, Row 40)

Average Resolution Time by Severity

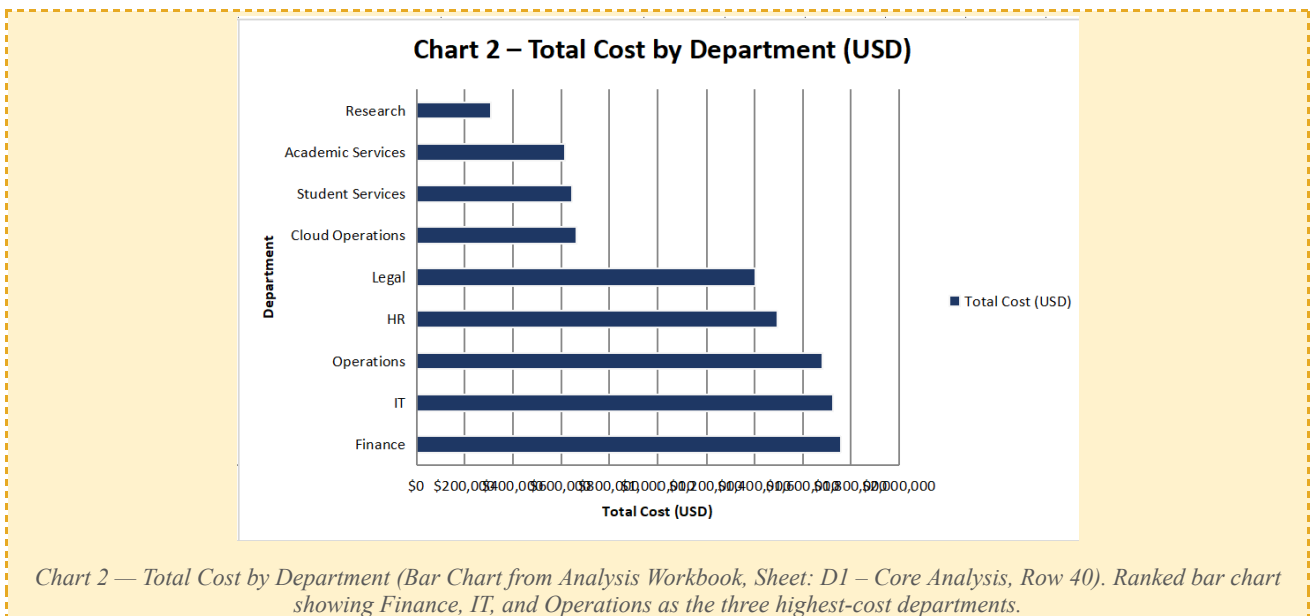
Severity	Avg Resolution (Days)	SLA Target (Days)	Governance Implication
Critical	9.80	3	Resolved faster than High/Medium — Board escalation drives prioritisation; but still 3× SLA target
High	12.72	7	74% SLA breach rate on closed incidents — resolution significantly exceeds target
Medium	14.74	14	Marginally exceeds target; large unresolved backlog (31 Pending)

Low	18.15	30	Within SLA for most closed incidents; no governance concern
-----	-------	----	---

The counterintuitive finding — that Critical incidents resolve faster than High incidents — reflects the impact of Board-level escalation pressure. This is a governance success indicator but also reveals that High incidents do not receive equivalent resource prioritisation despite their 74% SLA breach rate.

Total Cost Impact by Department

Department	Total Cost (USD)	Incident Count	Avg Cost (USD)
Finance	\$1,756,282	33	\$53,221
IT	\$1,725,965	30	\$57,532
Operations	\$1,682,059	32	\$52,564
HR	\$1,493,242	25	\$59,730
Legal	\$1,403,244	26	\$53,971
Cloud Operations	\$663,410	10	\$66,341
Student Services	\$643,730	8	\$80,466
Academic Services	\$617,870	10	\$61,787
Research	\$307,620	6	\$51,270



Total Cost Impact by Responsible Team

Responsible Team	Total Cost (USD)	Incidents Managed	Avg Cost per Incident
Compliance	\$2,836,299	42	\$67,531
DevOps	\$2,079,986	33	\$63,030
IT Security	\$1,763,143	38	\$46,398
SOC	\$1,624,054	36	\$45,113
GRC	\$964,680	11	\$87,698
Incident Response	\$646,370	14	\$46,169
IAM	\$283,670	3	\$94,557
Cloud Security	\$95,220	3	\$31,740

The Compliance team manages the highest total cost portfolio (\$2.8M, 42 incidents) but has a relatively low SLA breach rate (8 breaches of 22 closed = 36%) compared to IT Security (15/24 closed = 63%). The GRC and IAM teams, despite small portfolios, show the highest average cost per incident, pointing to the complexity of the incident types they handle.

Top 3 Incident Types by Average Cost

Rank	Incident Type	Avg Cost (USD)	Total Cost	Governance Significance
1st	Insider Threat	\$138,506	\$692,530	Critical — highest average; low volume means each incident is catastrophic
2nd	Cloud Exposure	\$94,846	\$1,043,310	Critical — 2025-only; fastest growing; driven by IAM misconfiguration
3rd	Third-Party Breach	\$92,888	\$557,330	High — supply-chain risk; third-party costs 41.7% more on average

Open and In-Progress Incidents: 46 of 180 incidents are either Open (23) or In Progress (23), representing 25.6% of the total portfolio. This is a significant governance concern — over one-quarter of incidents are unresolved, including incidents with material regulatory exposure.

D2. Advanced Governance Analysis

SLA Breach Patterns by Severity and Responsible Team

The analysis of the closed incidents shows that there is a clear concentration of SLA breach at High severity level. Out of 34 closed High incidents, 25 breached SLA (74% breach rate). 12 out of 17 closed Critical incidents breached SLA (71%). The Medium incidents have a 35% breach rate. All Low incidents are closed without breach of SLA (0% breach rate).

Among teams, IT Security breaches the SLA most often among closed incidents (15 out of 24 = 63%), followed by DevOps (13 out of 25 = 52%). SOC has a 46% breach rate (11 out of 24). The Compliance team – responsible for the biggest portfolio – has a 36% closed SLA breach rate. The lowest breach rate is observed among Incident Response team (1 breach out of 10 closed incidents = 10%).

Governance implications: SLA breach pattern is not random; it concentrates in specific severity tiers (High) and specific teams (IT Security, DevOps). This means that there are some resource allocation issues rather than personal problems. The 7-day SLA is not achievable for High incidents due to resource limitations

Regulatory Exposure by Department and Incident Type

Finance ranks highest in regulatory exposure by type with 14 Financial Data incidents associated with regulatory risk, which are caused mainly by the Phishing, DDoS, and Data Leak incident types. Legal is the only group to have double regulatory and privacy exposure, both in terms of 10 incidents each. This group's position results from being both a data processing and advice-giving service.

IT has 14 Privacy-exposure incidents, just like Finance does. This shows the large amount of personal data that is processed via IT. HR has 4 Employment Data incidents, which means some obligation under the terms of employment regulations in several countries. Student Services and Academic Services have Education Records exposure, which indicates their obligations similar to those in FERPA.

Third-Party Involvement Analysis

Out of 180 incidents, 43 (or 23.9%) were third-party-related or vendor-related. The average cost for third-party incidents is \$73,700 while the average cost of non-third-party incidents is \$52,002, a difference of 41.7%. Third-party incidents also have a higher percentage of Critical severity with 14% of third-party incidents having Critical severity, compared to 9.3% of non-third-party incidents.

The top incidents for third parties include Cloud Exposure, Third-Party Breach, and Misconfiguration, which are all control failure incidents with an external supply chain component to them.

Control Domain Requiring Increased Governance Attention

Privileged Access and Monitoring is the control domain that requires immediate governance intervention. Although having only 5 incidents, it has the highest average cost per incident of any domain at \$138,506, which is 2.4 times greater than the overall portfolio average of \$57,890. The domain is associated solely with Insider Threat incidents, with three out of five incidents among the top ten most expensive incidents across the entire dataset (INC0131: \$245,560; INC0165: \$202,760; INC0111: \$191,110).

Cloud Security is the second governance priority because of its 2025-only emergence and \$94,846 average cost. The sharp growth in Cloud Exposure incidents (from zero to 11 in 2025) constitutes an increasing risk for which the governance infrastructure is not yet prepared.

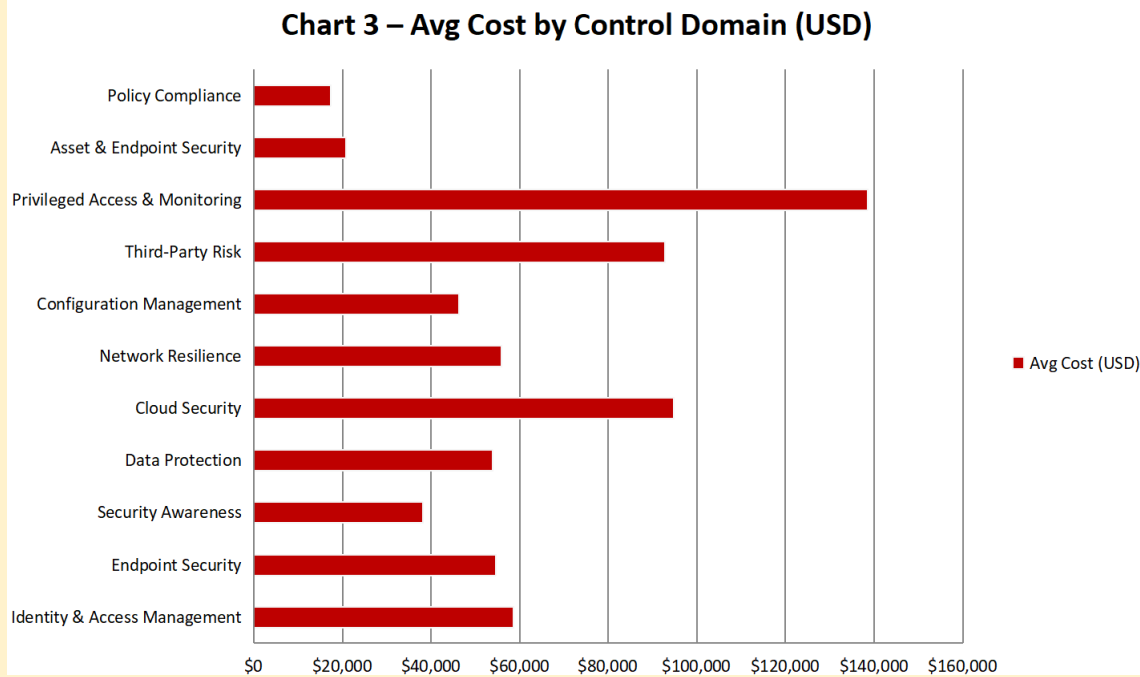


Chart 3 — Avg Cost by Control Domain (Bar Chart from Analysis Workbook, Sheet: D2 – Adv. Governance Analysis, Column A–B, starting Row 62). Shows Privileged Access & Monitoring as the highest-cost domain.]

D3. CISO / Board Insights

Insight 1: Identity and Access Management is the #1 Volume and Cost Driver — Immediate Remediation Required

Dimension	Detail
Finding	IAM is the leading control domain by incident count (33 incidents, 18.3% of total portfolio). The primary root causes are compromised credentials (9 incidents), excessive privileges (11 incidents), and dormant account misuse (9 incidents). Average cost: \$58,560. Total cost: \$1,932,473.
Supporting Data	33 incidents \$1,932,473 total cost Root causes: Excessive privileges (11), Dormant accounts (9), Compromised credentials (9) IAM failures link to Unauthorized Access (24 incidents) and Credential Theft (9 incidents) incident categories
Governance Significance	IAM is the primary attack surface enabler across all incident categories. Dormant accounts and excessive privileges are process failures, not technical ones — they indicate that joiner/mover/leaver processes and access certification processes are not functioning. Without fixing IAM governance, every other control improvement is undermined.
Accountable Role(s)	CISO (primary) IT Security / IAM Team (responsible) HR (joiner/leaver process) Department Heads (access certification sign-off)
Recommended Action	1. Implement quarterly access certification reviews for all users. 2. Mandate MFA for all privileged and remote access accounts (immediate). 3. Enforce automated dormant account deactivation after 30 days of inactivity. 4. Deploy identity governance tooling with automated access request workflows. 5. Integrate HR off-boarding with IAM de-provisioning within 4 hours of departure notification.
Owner	CISO / IT Security Lead / HR Director
Success Indicator	IAM-related incidents reduced by $\geq 30\%$ within 6 months; 100% MFA coverage for privileged accounts within 90 days; zero dormant account incidents within 120 days.

Insight 2: Privileged Access Incidents Are Low-Volume but Catastrophic — Insider Threat Governance Must Be Formalised

Dimension	Detail
Finding	The Privileged Access and Monitoring domain produces only 5 incidents but the highest average cost of any domain at \$138,506 — 2.4× the portfolio average. The three most expensive incidents in the dataset (INC0131: \$245,560; INC0165: \$202,760; INC0111: \$191,110) are all Insider Threat incidents in this domain.
Supporting Data	5 Insider Threat incidents \$692,530 total cost Avg \$138,506 INC0131 (\$245,560, Critical, HR, DevOps) INC0165 (\$202,760, Critical, Cloud Operations, GRC — currently Open) INC0111 (\$191,110, Critical, Operations, Compliance)
Governance Significance	A single insider threat incident at average cost exceeds the budget of most security teams. INC0165 remains Open — a Critical Insider Threat incident with contractual regulatory exposure that has not been resolved. This requires immediate Board visibility. The absence of a formalised insider threat programme means these events are detected reactively rather than prevented proactively.
Accountable Role(s)	Board / Executive (risk acceptance and programme approval) CISO (programme ownership) HR (personnel risk) Legal (investigation governance)
Recommended Action	1. Escalate INC0165 (Open Critical Insider Threat) to Board immediately — governance gap identified in this analysis. 2. Implement a Privileged Access Management (PAM) solution with session recording for all privileged accounts. 3. Establish a formal Insider Threat Programme with HR, Legal, and CISO joint governance. 4. Deploy User and Entity Behaviour Analytics (UEBA) on sensitive systems. 5. Enforce dual-approval for all data transfers >1GB from sensitive systems.
Owner	CISO / CRO / HR Director

Success Indicator	PAM solution deployed within 120 days; Insider Threat Programme charter approved within 60 days; INC0165 resolved and closed within 30 days; no undetected data exfiltration events in next 12 months.
-------------------	--

Insight 3: Cloud Exposure is an Emerging Catastrophic Risk with No 2024 Precedent — Cloud Governance is Urgently Required

Dimension	Detail
Finding	Cloud Exposure incidents did not appear in the 2024 dataset (INC0001–0100) but produced 11 incidents in 2025, averaging \$94,846 each (\$1,043,310 total). 8 of 11 Cloud Exposure incidents are caused by IAM misconfiguration or security group errors — preventable misconfigurations. The three most expensive Cloud Exposures (INC0131: \$245,560; INC0152: \$209,090; INC0146: \$161,640) are all Critical severity.
Supporting Data	11 incidents (all 2025) \$1,043,310 total \$94,846 avg 73% involve IAM misconfiguration or security group errors Third-party involvement in 7 of 11 incidents (64%) Highest-cost non-Insider incident type
Governance Significance	Cloud adoption is accelerating faster than governance. The third-party involvement rate of 64% in Cloud Exposure incidents indicates that cloud environments managed or configured by vendors are systematically under-governed. Without a Cloud Security Posture Management (CSPM) programme, this trend will compound as cloud footprint grows.
Accountable Role(s)	CISO CTO / Cloud Architecture Lead CRO Board Audit Committee (strategic oversight of cloud risk)
Recommended Action	1. Deploy a CSPM tool (e.g., Wiz, Prisma Cloud, or equivalent) with automated remediation for misconfigured resources. 2. Define Cloud Security governance policies and assign Cloud Operations as the accountable entity in the RACI. 3. Mandate cloud security reviews as a mandatory step in the change-control process. 4. Require third-party cloud vendors to demonstrate compliance with enterprise cloud security standards as a contract condition. 5. Report Cloud Security metrics to the Board Audit Committee quarterly.
Owner	CISO / Cloud Operations Lead / CTO
Success Indicator	CSPM operational within 90 days; cloud misconfigurations reduced by $\geq 50\%$ within 6 months; zero public storage exposure incidents in the following quarter; third-party cloud vendor compliance assessments completed for all active vendors within 120 days.

References

- CISA (2023). CISA CISO Handbook. US Cybersecurity and Infrastructure Security Agency. Available at: <https://www.cisa.gov/resources-tools/resources/cisa-ciso-handbook>
- NCSC (2022). Board Toolkit: Cyber Security for Directors. UK National Cyber Security Centre. Available at: <https://www.ncsc.gov.uk/collection/board-toolkit>
- US Securities and Exchange Commission (2023). Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure. Final Rule, 17 CFR Parts 229 and 249. Available at: <https://www.sec.gov/rules/final/2023/33-11216.pdf>
- HHS Office for Civil Rights (2024). Change Healthcare Cyber Attack. US Department of Health and Human Services. Available at: <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident/index.html>
- US Senate Finance Committee (2024). Testimony of Andrew Witty, CEO UnitedHealth Group, before the Senate Finance Committee, 1 May 2024.
- Mandiant / Google Cloud (2023). M-Trends 2023: Special Report. Mandiant. Available at: <https://www.mandiant.com/m-trends>
- ISACA (2024). State of Cybersecurity 2024. ISACA. Available at: <https://www.isaca.org/resources/reports/state-of-cybersecurity-2024>
- ISO/IEC 27001:2022. Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements. International Organization for Standardization.
- NIST (2018). NIST Cybersecurity Framework Version 1.1. National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.CSWP.04162018>
- European Union (2016). General Data Protection Regulation (GDPR), Regulation (EU) 2016/679.
- Nigeria Data Protection Commission (2023). Nigeria Data Protection Act 2023. Federal Government of Nigeria.
- Fruhlinger, J. (2023). SolarWinds hack explained: Everything you need to know. CSO Online. IDG Communications.
- Cichonski, P., Millar, T., Grance, T. & Scarfone, K. (2012). NIST SP 800-61 Rev. 2: Computer Security Incident Handling Guide. NIST.
- Patel, N. (2024). Change Healthcare Hack: Timeline and Impact. STAT News, March–October 2024.

AI Use Declaration

This assignment was completed with the assistance of Claude (Anthropic) for structural guidance, language refinement, and dataset analysis support. Gemini for generating diagrams. All governance reasoning, analytical conclusions, recommendations, and chart interpretations are the author's own work. All cited sources have been verified as real and publicly accessible